

طرح یکپارچه سازی بافه، رشن و داشبورد مدیریت

2026-09-18 · @Someone

حکم: شدنی است، با دو شرط

بله — هر سه سامانه قابل یکپارچه سازی اند، حتی اگر هر کدام روی هاست کاملاً جدا باشند. این ادعا از روی حدس نیست؛ کد هر سه بسته خوانده شده و مسیر اتصال در آن‌ها باز است.

را `/wp-admin/` و `wp-login.php` دلیل فنی اش یک جمله است: قفل ورود هر دو افزونه فقط از بیرون در دسترس است و کانکتور بدون REST کاری ندارد. یعنی مسیر `/wp-json/` می بندد و به دست زدن به قفل کار می کند.

آنچه شدنی است

خواسته	حکم
ورود یک بار به داشبورد و رفتن به پنل بافه بدون رمز	شدنی — با توکن یک بار مصرف
همین برای رشن	شدنی — با همان مکانیزم
گزارش و آمار هر دو سایت در یک جا	شدنی
کار کردن همه این‌ها روی سه هاست جدا	شدنی — فقط کندتر و نیازمند تنظیم بیشتر
مدیریت کارکنان، حضور و غیاب، حقوق، مرخصی، وام	شدنی — ولی از صفر ساخته می شود

آنچه شدنی نیست و باید انتظارش را نداشت

در داشبورد. دو مانع مستقل دارد که هیچ کدام دور زدن (iframe) باز شدن پنل بافه داخل قاب ۱. نیستند وقتی دامنه‌ها جدایند؛ مرورگرهای امروز کوکی ورود بافه را داخل قاب سایت دیگر نمی فرستند، و نمی فرستد. پنل بافه در تب تازه باز می شود، نه داخل داشبورد. از دید کاربر CORS افزونه هیچ هدر تفاوتش فقط یک تب است — بدون رمز وارد می شود و این همان چیزی است که می خواستید.

حضور و غیاب ضد جعل با مرورگر. موقعیت مکانی در مرورگر قابل جعل است و هیچ راه وی برای ۲. بستنش وجود ندارد. آنچه شدنی است؛ تشخیص و پرچم زدن موارد مشکوک، که تصمیم خودتان هم همین بود.

یکی شدن دیتابیس‌ها. هر سایت دیتابیس خودش را نگه می دارد. داشبورد داده را می خواند و کش ۳. می کند، نه اینکه جدول‌ها یکی شوند. این محدودیت نیست، تصمیم درست است — وگرنه خرابی یکی، هر سه را می خواباند.

دو شرطی که باید برآورده شوند

و برای خروجی اکسل به `php-soap` **شرط اول — پیش نیازهای هاست**، بافه برای پیامک به روی هاست نباشد، پیامک هیچ وقت کار نمی کند و این را تنها وقتی `soap` نیاز دارد. اگر `ZipArchive` برای همین ساخته شد و باید **پیش از** `host-check.php` می فهمید که همه چیز ساخته شده باشد، ابزار **هر کار دیگری** روی هر سه هاست اجرا شود.

شرط دوم — تماس سرور به سرور باید باز باشد، داشبورد از این راه داده می گیرد، بعضی هاست های اشتراکی تماس خروجی یا لوپ بک را می بندند، همان ابزار این را هم می سنجد. اگر این دو برقرار باشند، بقیه اش کار مهندسی معمولی است — نه ریسک

وضعیت فعلی سه سامانه

هر سه بسته خوانده شده اند، خلاصه آنچه در دست دارید

بافه — افزونه بیکری ۶.۴.۲

سه نقش وردپرسی، REST برای کافه ها، ۱۵ جدول اختصاصی، ۵۶ مسیر B2B سامانه سفارش عمده آماده و قابل استفاده دوباره: سیستم اعتبار با قفل سطری دیتابیس، درگاه زیبال، پیامک ملی پیامک با `wp-admin` تقویم جلالی، خروجی اکسل با نمودار، گفتگوی داخل اپ، و قفل ورود که `retry` صف و دید بیرون پنهان می کند.

بسته اند، هیچ توکن، `nonce` به کوکی وردپرس و `bk/v1` ندارد: هیچ احراز هویت ماشینی. تمام مسیرهای در کل افزونه نیست. این تنها چیزی است که برای اتصال کم دارد HMAC یا API کلید

نکته مهم: افزونه یک الگوی درست برای جابه جایی هویت دارد — «حالت تماشا» که هویت را فقط در یک تکرار شود SSO نقطه عوض می کند و یک دروازه واحد روی همه درخواست ها می گذارد. همین الگو باید در بین دامنه ای کار نمی کند (وردپرس `nonce`) — هر چند مکانیزمش

پتی پتی — افزونه منو ۲.۲.۱ (پایه رشن)

تقریباً کپی معماری بافه: همان قفل ورود، همان پنل روی سایت، همان فرم ورود اختصاصی. تفاوت: داده است نه جدول اختصاصی — که برای یک منو انتخاب درستی است `post type` روی

یافته مهم: پتی پتی هیچ سفارشی ندارد — نه سبد، نه مشتری، نه پرداخت، یک منوی نمایشی برای روی میز است، چون رشن هم قرار است فقط نمایشی باشد، این دقیقاً مناسب است QR

گوگل، هر دو CDN دو محدودیت که باید برداشته شوند: سقف خاموش ۵۰۰ آیت، و وابستگی فونت به در بخش مربوط به رشن توضیح داده شده اند.

وجود دارد. `padding-left` یا `margin-right` منو، صفر مورد CSS خبر خوب: در کل ۹۶۷ خط روی ریشه، یعنی پشتیبانی از زبان چپ به راست `direction: rtl` است با یک `flexbox` همه چیز تقریباً رایگان است.

معدن قطعات — ۱.۵۱.۴ qk-crm

این افزونه برای کسب و کار دیگری است، ولی **سه چیز در آن هست که مستقیماً به داشبورد می خورد** و دوباره نوشتنشان اتلاف وقت است:

دسترسی های عمل (مثل ویرایش فروش) از `class-roles.php` **مدل نقش * دامنه**. در ۱. دسترسی های دامنه (خودم / تیمم / همه) جدا شده اند. این دقیقاً همان مدلی است که منابع انسانی لازم دارد.

اجرا سوار بر هر درخواست، با قفل اتمیک دیتابیس، پس از ارسال **wp-cron** **زمان بند مستقل** از ۲. پاسخ، این مسئله ای است که حقوق و دستمزد از آن می ترسد و شما حلش کرده اید.

قفل دوره ماهانه در موتور پورسانت — همان الگویی که برای تغییر ناپذیری فیش حقوقی لازم است ۳. **حضور و غیاب، حقوق و فیش در آن نیست**. فقط دو نوع تیکت مرخصی دارد. پس دامنه منابع انسانی کاملاً از صفر ساخته می شود — ولی روی زیرساختی که از قبل آزموده شده.

نتیجه عملی

هر سه افزونه یک سبک معماری مشترک دارند: اپ تک صفحه ای روی یک مسیر، پنل اختصاصی خارج از پیشخوان، نقش های اختصاصی، و قفل ورود. **داشبورد هم باید همین سبک را دنبال کند** — یعنی qk-crm افزونه وردپرس روی اسکلت

معماری هدف

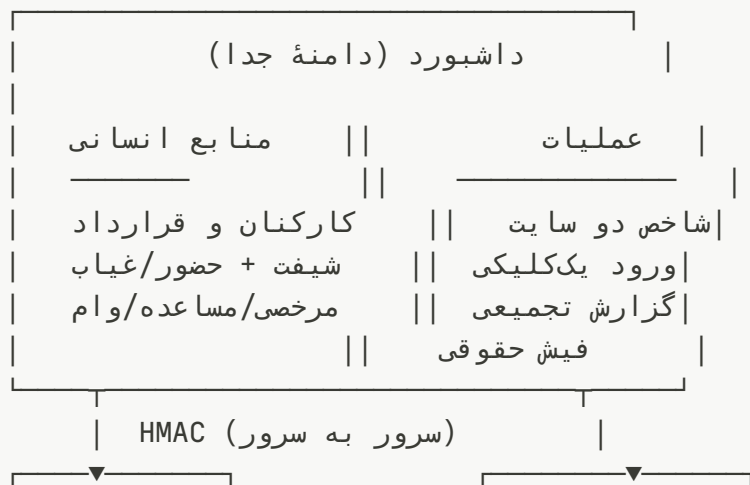
سه سایت مستقل، هر کدام با دیتابیس خودش، که فقط از راه یک قرارداد مشخص با هم حرف می زنند

مرورگر کاربر

|

| (یک بار ورود)

▼



bafeh.com	رشن
منو + کانکتور	بیکری + کانکتور
دیتا بیس خودش	دیتا بیس خودش

سه قاعده که همه طراحی رویشان می چرخد

قاعده ۱ — هر تماس بین سامانه ها سرور به سرور است. مرورگر کاربر هرگز مستقیم به بافه یا رشن وصل نمی شود، این نه یک سلیقه، که نتیجه قطعی این است که دامنه ها جدایند و نه کوکی CORS. مشترک دارند و نه

قاعده ۲ — داشبورد داده را می کشد و کش می کند، نه اینکه سایت ها بفرستند. هر چند دقیقه یک بار می پرسد و جواب را در دیتابیس خودش نگه می دارد. سه فایده: اگر بافه پایین باشد داشبورد همچنان عدد نشان می دهد (با برجسب «آخرین به روزرسانی»); روند تاریخی حتی اگر سایت مبدأ داده اش را پاک کند، می ماند؛ و نرمال سازی یک جا اتفاق می افتد.

قاعده ۳ — منبع حقیقت «آدم ها» داشبورد است. هر سایت فقط حساب عملیاتی خودش را دارد. رکورد کارمند در داشبورد می نشیند و فقط یک لینک به حساب هر سایت دارد. اگر این را وارونه کنید، سؤال «این آدم کیست» سه جواب پیدا می کند.

مرز عملیات و منابع انسانی

درون داشبورد دو دامنه کاملاً جدا وجود دارد که فقط از یک نقطه به هم می رسند: **کارمند کارگاه بافه، همان آدمی است که رکورد حضورش ثبت می شود.**

این مرز را از روز اول در دیتابیس هم بکشید (پیشوند جدول جدا). دلیلش عملی است: اگر فردا سایت سومی اضافه شود فقط بخش عملیات لمس می شود، و اگر روزی خواستید منابع انسانی را جدا کنید، قابل جدا شدن است.

قرارداد کانکتور — قلب یکپارچه سازی

این مهم ترین بخش سند است. **یک قرارداد، که هر دو سایت عیناً همان را پیاده می کنند.** اگر بافه و داشته باشند، هر قابلیت تازه داشبورد باید دو بار نوشته شود — تا ابد API رشن دو شکل متفاوت

مسیرها

موجود است — عمداً، تا مسیرهای `bk/v1` این جدا از `hub/v1`: تازه می سازد namespace هر سایت یک فعلی اصلاً لمس نشوند.

مسیر	کار
GET /hub/v1/ping	سلامت، نسخه، و فهرست امکانات
GET /hub/v1/stats	شاخص های نرمال شده در بازه تاریخی

مسیر	کار
GET /hub/v1/orders	فهرست سفارش — فقط اگر سایت سفارش داشته باشد
GET /hub/v1/accounts	حساب‌های سایت، برای لینک به رکورد کارمند
POST /hub/v1/sso/mint	ساخت توکن ورود یک بار مصرف

فهرست امکانات برمی‌گرداند ping چرا

بافه سفارش و اعتبار و فاکتور دارد؛ رشن فقط منوی نمایشی است. به جای اینکه داشبورد پر از شرط «اگر بافه بود، اگر رشن بود» شود، خود سایت اعلام می‌کند چه دارد:

```
{
  "site": "bafeh",
  "version": "6.5.0",
  "features": {
    "orders": true,
    "credit": true,
    "invoices": true,
    "menu_views": false
  }
}
```

را `orders` داشبورد کارتی را که سایت ندارد اصلاً نشان نمی‌دهد. فردا اگر رشن سفارش هم گرفت، فقط می‌کند و داشبورد بدون تغییر کد، کارت سفارش‌ها را نشان می‌دهد `true`.

HMAC احراز هویت: امضای

هر درخواست یک هدر امضا دارد:

```
X-Hub-Key: <شناسه کلید>
X-Hub-Time: <یونیکس timestamp>
X-Hub-Nonce: <رشته تصادفی>
X-Hub-Sign: HMAC-SHA256( بدنه + sha256(متد + مسیر + time + nonce )
```

بیش از ۵ دقیقه فاصله نداشته باشد، و `time`، سایت گیرنده سه چیز را می‌سنجد: امضا درست باشد `nonce` قبلاً مصرف نشده باشد.

وردپرس؟ وردپرس از نسخه ۵.۶ رمزهای اختصاصی دارد و **Application Password** و نه **HMAC** چرا است: **رمز روی هر درخواست رد و بدل می‌شود**. یک خط Basic auth راه سریع‌تری است. ولی آن لاگ لورفته فقط، HMAC لاگ که جایی ذخیره شود یعنی کلید لو رفته و هرکس می‌تواند هر کاری بکند. با امضای یک درخواست منقضی‌شده را نشان می‌دهد — بی‌ارزش. نیم‌روز کار بیشتر برای داده‌ای که پول در آن است می‌ارزد.

شکل پاسخ — نرمال شده

هر دو سایت **همین شکل** را برمی گردانند، حتی اگر درونشان جدول های کاملاً متفاوتی باشد:

```
{
  "range": { "from": "1405-06-01", "to": "1405-06-31" },
  "metrics": {
    "revenue": { "value": 184500000, "unit": "toman" },
    "orders": { "value": 342 },
    "customers": { "value": 28 }
  },
  "daily": [ { "date": "1405-06-01", "revenue": 5200000, "orders": 11 } ]
}
```

نکته: **تاریخ ها شمسی و مبلغ ها تومان و عدد خام اند**. نه رشته فرمت شده، نه جداکننده هزارگان. فرمت کار لایه نمایش است — وگرنه داشبورد برای جمع زدن دو عدد باید اول رشته را پارس کند.

چرا همین قرارداد روی هاست های جدا هم کار می کند

است. هیچ فرضی درباره اینکه دو سایت کجا نشسته اند **HTTPS** این نکته کلیدی است: **قرارداد فقط** ندارد — نه دیتابیس مشترک، نه فایل سیستم مشترک، نه حتی همان کشور

پس تفاوت «همه روی یک هاست» و «هر کدام روی هاست جدا» **صفر خط کد** است. فقط دو چیز عوض می شود: نشانی پایه در تنظیمات، و سرعت (روی یک هاست چند میلی ثانیه، روی هاست های جدا شاید ۲۰۰ میلی ثانیه). چون داشبورد کش می کند، کاربر این تفاوت را حس نمی کند.

یک مراقبت روی هاست مشترک: اگر هر سه روی یک سرور باشند، بعضی هاست ها تماس سایت به دقیقاً این `host-check.php` را می بندند — که مسخره است ولی پیش می آید. ابزار (loopback) خودش را می سنجد.

ورود یکپارچه — بدون وارد کردن اطلاعات

خواسته اصلی شما: یک بار به داشبورد وارد می شوید، بعد روی «پنل بافه» می زنید و بدون رمز وارد می شوید.

جریان دقیق

۱. کاربر در داشبورد روی «پنل بافه» میزند
۲. سرور داشبورد (نه مرورگر) → بافه:
POST /hub/v1/sso/mint
شناسه کاربر مقصد + HMAC امضای
۳. نگه می‌دارد transient بافه یک توکن می‌سازد و در:
 - عمر: ۶۰ ثانیه
 - یک بار مصرف
 - گره خورده به همان یک کاربر
۴. مرورگر به تب تازه می‌رود:
bafteh.com/bakery/panel?sso=<token>
۵. افزونه توکن را مصرف می‌کند (حذف فوری)
→ wp_set_auth_cookie()
→ ریدایرکت به نشانی تمیز بدون توکن

از دید کاربر: یک کلیک، یک تب تازه، وارد شده

سه قاعده که نباید شکسته شوند

توکن یک بار مصرف و کم عمر. اگر توکن دو بار کار کند، هرکس که نشانی را از تاریخچه مرورگر یا لاگ پراکسی بردارد وارد پنل می‌شود.

هرگز از مرورگر قابل صدا زدن نباشد. فقط سرور به سرور، فقط با امضای mint مسیر ۲. اگر این مسیر از مرورگر باز باشد، هر کاربری می‌تواند برای هر کس دیگری توکن بسازد. HMAC.

۳. رمز سایت مقصد هرگز در داشبورد ذخیره نشود.

قاعده سوم را جدی بگیرید. راه حلی که خیلی‌ها می‌روند این است که رمز کاربر را در داشبورد ذخیره کنند و فرم ورود را خودکار پر کنند. **این یعنی رمز همه کاربران هر دو سایت، در یک دیتابیس، به شکل قابل بازیابی.** یک نشستی و همه چیز رفته. توکن یک بار مصرف دقیقاً همان نتیجه را بدون این ریسک می‌دهد.

دو چیزی که اغلب فراموش می‌شوند

خروج هماهنگ. وقتی کاربر از داشبورد خارج می‌شود، نشست‌های بافه و رشن هم باید بسته شوند. روی کامپیوتر مشترک کارگاه، فراموش کردن این یعنی نفر بعدی وارد پنل بافه است.

کاربری که در سایت مقصد وجود ندارد. کانکتور می‌تواند حساب را خودکار بسازد — ولی فقط با نقشی که داشبورد صریح اعلام کرده، و هرگز نقشی بالاتر از آنچه کاربر در داشبورد دارد.

نکته مهم درباره قفل ورود

`/wp-` قفل ورود هر دو افزونه سر جایش می ماند و **اصلاً لازم نیست دستکاری شود**. چون این جریان از `wp-admin` می گذرد که قفل به آن کاری ندارد، و مقصد نهایی هم پنل روی فرانت است نه `json/` این. `wp-admin` می گذرد که قفل به آن کاری ندارد، و مقصد نهایی هم پنل روی فرانت است نه `json/` این. مزیت بزرگی است: امنیت فعلی دست نخورده می ماند.

تغییرات لازم در بیکری ساخته شده

خبر خوب را اول بگویم: **هیچ یک از این تغییرات به منطق موجود دست نمی زند**. نه سیستم اعتبار، نه سفارش، نه درگاه، نه پیامک، نه پنل. همه کار افزودن است، نه تغییر دادن.

کار ۱ — مازول کانکتور (اصلی)

یک پوشه تازه: `includes/modules/hub/`

<code>class-hub-auth.php</code>	→ اعتبارسنجی امضای HMAC
<code>class-hub-api.php</code>	→ مسیرهای <code>hub/v1</code>
<code>class-hub-sso.php</code>	→ ساخت و مصرف توکن ورود
<code>class-hub-stats.php</code>	→ ترجمه داده بیکری به شکل قرارداد

در هوک `register_routes()` و صدا زدن autoloader ثبت کلاس ها در: `bakery.php` و سه خط در `rest_api_init`. همین.

باید همان توابعی را صدا بزنند که پنل خود بیکری صدا `class-hub-stats.php`: **نکته طراحی می زند**، نه اینکه کوئری موازی بنویسد. اگر دو منطق جدا باشند، با گذشت زمان از هم فاصله می گیرند و داشبورد عددی نشان می دهد که با پنل نمی خواند. خود افزونه این درس را قبلاً گرفته: در تغییرات نسخه ۶.۳.۱ نوشته شده که داده پیش نمایش عمداً از همان توابع می آید «وگرنه دو منطق جدا با گذشت زمان از هم فاصله می گرفتند».

کار ۲ — صفحه کلیدها در پنل

یک بخش کوچک در تنظیمات که:

- را می سازد و فقط یک بار نشان می دهد HMAC کلید
- امکان باطل کردن و ساخت کلید تازه می دهد
- آخرین تماس های داشبورد را لاگ می کند (کی، کی، چه مسیری)

آن لاگ را دست کم نگیرید. روزی که عددی در داشبورد عجیب باشد، تنها راه فهمیدن اینکه داشبورد اصلاً پرسیده بوده یا نه، همین لاگ است.

کار ۳ — دو اصلاح کوچک امنیتی

است. `brute-force` بافه از آن استفاده نمی کند و مسیر معمول حمله `XML-RPC (الف)` خاموش کردن دارد و بافه ندارد — همان کد قابل انتقال است `class-pp-stealth.php` افزونه پتی پتی این را در

برای مهمان. این مسیر نام کاربری همه حساب‌ها را به هر بازدیدکننده‌ای `/wp/v2/users` (ب) **بستن** را پنهان می‌کند، wp-admin می‌دهد. پتی‌پتی این را هم بسته، بافه نه. با توجه به اینکه قفل ورود بافه عمداً باز گذاشتن این مسیر همان در را از پنجره باز می‌کند.

کار ۴ — نگاشت کارمند

ساده که می‌گوید این حساب وردپرسی، متناظر کدام کارمند در داشبورد است. user meta یک ستون یا یک همین را برمی‌گرداند `accounts` مسیر

یک جمله برای روشن شدن مرز: **نقش‌های وردپرسی بافه دسترسی به بافه را اداره می‌کنند، نه جایگاه شغلی طرف را.** این دو را قاطی نکنید.

آنچه لازم نیست انجام شود

این فهرست هم‌اندازه فهرست بالا مهم است:

- قفل ورود دستکاری نمی‌شود
- اضافه نمی‌شود (چون تماس‌ها سرور-به-سرورند) CORS هیچ هدر
- دیتابیس بافه جابه‌جا نمی‌شود
- پنل فعلی بازنویسی نمی‌شود
- منطق اعتبار و سفارش لمس نمی‌شود

برآورد: این کارها روی هم چند روز کار است، نه چند هفته — چون هیچ کدام به منطق پیچیده موجود دست نمی‌زنند. به همین دلیل **این باید اولین فاز اجرایی باشد:** کم‌ریسک، کوتاه، و فرض بنیادین کل طرح («این دو سامانه واقعاً به هم وصل می‌شوند؟») را زود اثبات می‌کند.

تغییرات لازم در رشن

رشن روی پتی‌پتی ۲.۲.۱ ساخته می‌شود: منوی نمایشی، چندزبانه، با آیتم‌های بسیار بیشتر.

کار ۱ — برداشتن سقف خاموش ۵۰۰ آیتم

کار می‌کند. آیتم ۵۰۱ به بعد بدون هیچ خطایی `posts_per_page => 500` تابع بارگذاری منو با **ناپدید می‌شود.** نه پیامی، نه هشدار — فقط نیست.

سمت سرور رندر می‌شود. با ۹۳ HTML ولی مسئله واقعی خود سقف نیست: **کل منو در یک صفحه** قلم عالی است؛ با چندصد قلم و عکس، صفحه‌ای می‌شود که مشتری گرسنه سر میز روی اینترنت موبایل باید منتظرش بماند.

راه‌حل: بارگذاری دسته‌به‌دسته — اول فقط دسته فعال، بقیه با ضربه روی تب. به علاوه `loading="lazy"` روی عکس‌ها.

گوگل CDN کار ۲ — قطع وابستگی فونت به

وصل `fonts.googleapis.com` به fallback را محلی همراه دارد، ولی در حالت Sahel افزونه فونت مسدودکننده، دقیقاً stylesheet می شود. در ایران این یعنی کند یا بسته — و بدترین جای ممکن برای یک QR می کند همان صفحه ای است که مشتری با

متن باز است — محلی بگذارید و آن خط را بردارید. کاریک ساخته است Vazirmatn فونت

کار ۳ — چندزبانه

نصب نکنید. سه دلیل: پنل رشن اختصاصی است و از پیشخوان رد نمی شود پس این **WPML یا Polylang** پیشخوان قلاب می زنند با آن درگیرند؛ هر دو برای هر زبان یک پست جدا می سازند که UI افزونه ها که به پولی است WPML تعداد ردیف را سه برابر می کند؛ و

روی همان آیتم meta به جایش: ترجمه به صورت

فیلدهایی که ترجمه می خواهند دقیقاً این ها هستند و بس: عنوان، توضیح، یادداشت قیمت، برجسب — به علاوه نام دسته بندی ها

```
_pp_name_en    _pp_desc_en    _pp_price_note_en    _pp_badge_en
_pp_name_ar    _pp_desc_ar    ...
```

و قاعده بازگشت: **ترجمه نبود ← فارسی نشان بده**

واحد؟ چون **حالت عادی کار، ترجمه ناقص است** — امروز پنجاه قلم JSON چرا کلید جدا و نه یک ترجمه می شود و هفته بعد پنجاه تای دیگر. با کلید جدا، هر قلم ترجمه نشده خودبه خود فارسی می ماند و هیچ جا خالی نمی شود.

و منطقش برای منو درست است: **قیمت پیتزا به زبان بستگی ندارد.** یک آیتم، یک قیمت، یک عکس، یک وضعیت موجودی — فقط کلمه ها عوض می شوند

مسیرها — و یک نکته فیزیکی مهم

```
/menu/        فارسی (پیش فرض، بدون پیشوند) ←
/menu/en/     انگلیسی ←
/menu/ar/     عربی ←
```

کدها روی میزها چاپ شده اند و نشانی شان قابل تغییر نیست. QR فارسی **باید بدون پیشوند بماند**، چون QRها این نکته ای است که در طراحی نرم افزار راحت فراموش می شود و بعد یعنی چاپ دوباره همه

وگرنه لینکی که مشتری برای دوستش می فرستد — localStorage تعیین شود نه فقط URL زبان از روی زبانش را از دست می دهد.

خبر خوب درباره چپ به راست

است با یک flexbox منو، **صفر مورد** ویژگی فیزیکی چپ/راست وجود دارد. همه چیز CSS در کل ۹۶۷ خط روی ریشه. پس برای انگلیسی فقط همان یک خاصیت عوض می شود و بقیه خودش `direction: rtl` را نوشته درست نوشته CSS می چرخد. کسی که این

ارقام: فارسی و عربی ارقام خودشان، انگلیسی ارقام لاتین. بافه تبدیل رقم را از قبل دارد و همان الگو قابل انتقال است.

کار ۴ — کانکتور

چون رشن را از صفر می سازید، این فرصتی. `features.orders = false` همان قرارداد بافه، با است که بافه نداشت: قرارداد را از روز اول درست پیاده کنید، نه اینکه بعداً وصله بزنید. گزارشی که رشن می دهد فرق دارد با بافه: بازدید منو، پربازدیدترین اقلام، تفکیک زبان، ساعت های اوج. این داده واقعاً ارزشمند است — می گوید مشتری چه را نگاه می کند و نمی خرد، که هیچ سیستم سفارشی نمی تواند بگوید.

داشبورد مرکزی

روی دامنه جدا، دو بخش جدا دارد، qk-crm افزونه وردپرس روی اسکلت

بخش عملیات

کار ساده ای است: شاخص های دو سایت کنار هم، دکمه ورود یک کلیک به هر پنل، و گزارش تجمیعی دو جدول بیشتر لازم ندارد: یکی برای ثبت سایت های متصل (نشانی، کلید، آخرین تماس موفق)، و یکی برای کش شاخص ها.

بخش منابع انسانی — کار اصلی

شیفت بندی (اول از همه)

این در صورت مسئله شما نبود ولی بدون آن حضور و غیاب معنا ندارد. «تأخیر» بدون ساعت شروع موعود تعریف ندارد، «غیبت» بدون «امروز شیفت داشت» تعریف ندارد. حقوق هم بدون این دو محاسبه نمی شود.

حضور و غیاب مکان محور

ساختار رکورد — این را از روز اول درست بسازید، چون بعداً میلیون ها ردیف دارد

```

employee_id • location_id • type (in/out)
recorded_at (زمان سرور) • client_at (زمان دستگاه)
lat • lng • accuracy_m • distance_m (محاسبه سرور)
method (gps / qr / manual / admin)
status (ok / flagged / rejected)
flags (JSON)
device_id • ip • user_agent
reviewed_by • reviewed_at • review_note

```

می فرستد. فاصله را سرور با فرمول **lat, lng, accuracy** **قاعده طلایی: مرورگر فقط** هاورساین حساب می کند. هرگز کلاینت نگویید «من داخل محدوده ام». کل امنیت این بخش روی همین یک خط می چرخد.

غیرمنتظره • دستگاه تازه • سفر IP • **پرچم هایی که از ابتدا لازم اند:** خارج از محدوده • دقت پایین ناممکن • مختصات یخ زده • ارسال با تأخیر • ثبت تکراری

دو نکته که بعداً گران تمام می شوند اگر حالا نباشند: نگه داشتن **هم زمان سرور و هم زمان دستگاه** روی QR از همین حالا — تا فردا که خواستید **method** (اختلافشان خودش یک سیگنال است)، و ستون **یا اپ نیتو اضافه کنید، جدول عوض نشود**.

درباره شعاع ۷۰۰ متر

متر یعنی محدوده ای حدود ۱.۵ کیلومتر مربع. کافه بغلی، خانه کارمند و ایستگاه مترو هم درونش جا ۷۰۰ می شود.

داخل ساختمان خطا دارد و با شعاع کم، آدم های واقعی GPS حدس می زنم این عدد را انتخاب کرده اید چون **رد می شدند. راه درست شعاع بزرگ نیست، منطق آگاه از دقت است**

فاصله + دقت > شعاع → قبول قطعی
 فاصله - دقت < شعاع → خارج، پرچم
 در غیر این صورت → مشکوک، پرچم

با این منطق می توانید شعاع را به ۱۵۰-۲۰۰ متر بیاورید و همچنان کسی که واقعاً داخل ساختمان است رد نشود. **و شعاع را در جدول مکان ها بگذارید، نه در کد** — بافه و رشن دو جای فیزیکی متفاوت اند.

مرخصی، مساعده، وام — یک موتور، نه سه مازول

هر سه یک شکل دارند: **درخواست با محتوای تایپ دار + زنجیره تأیید + ماشین وضعیت + اثر مالی یا تقویمی هنگام تصویب**.

اگر سه مازول جدا بنویسید، سه بار زنجیره تأیید می نویسید و بار چهارم (مثلاً درخواست مأموریت) از نو

نوع	اثر تأیید
مرخصی	کسر از مانده + روز حضور «غایب» نشود + اثر روی حقوق

نوع	اثر تأیید
مساعده	یک کسر روی فیش ماه بعد
وام	فیش بعدی N اصل + جدول اقساط، کسر روی

حساب مالی کارمند دقیقاً همان الگوی اعتبار بافه است: یک مانده و یک دفتر کل با مانده پس از هر ردیف، این الگو در همین کدبیس آزموده شده — دوباره اختراعش نکنید.

فیش حقوقی — دو قاعده حیاتی

هیچ نرخ در کد نباشد. ضریب اضافه کاری، درصد بیمه، پله های مالیات، حق اولاد، حق مسکن، بن — ۱۰ همه در جدولی با ستون «از تاریخ»، هر سال بودجه که می آید، **ردیف تازه اضافه می شود، ردیف قبلی دست نمی خورد.**

اعداد دقیق را باید حسابدار خودتان تأیید کند — هر سال عوض می شوند و من نباید از حافظه بنویسمشان. کاری که ساختار باید بکند این است که عوض کردنشان یک ردیف دیتابیس باشد، نه یک دیپلوی.

در خود فیش snapshot **فیش صادر شده تغییر ناپذیر است.** لحظه صدور، تمام ورودی ها به صورت ۲۰ ذخیره می شوند، اصلاح = فیش اصلاحی تازه، نه ویرایش قدیمی.

و کدبیس خودتان هر دو الگو را از قبل دارد: بافه قیمت تمام شده را روی خود قلم فاکتور ثبت می کند و qk-crm نه ارجاع به محصول — دقیقاً به این دلیل که تغییر بعدی هزینه نباید فاکتورهای قدیمی را عوض کند. و قفل دوره ماهانه دارد، هر دو عیناً قابل انتقال اند.

را دارد BK_Jalali دوره حقوق روی **مرز ماه شمسی** است، نه میلادی. بافه

نقش ها

دارد. نقش می گوید «چه کاری»، دامنه می گوید «روی qk-crm مدل **نقش * دامنه** — عیناً همان چیزی که «چه کسانی

مجموعه واقع بینانه: مالک، مدیر منابع انسانی، مالی، مدیر شعبه (فقط تیم خودش)، کارمند (خودسرویس)، ناظر فقط خواندنی.

مدیر شعبه بافه نباید کارکنان رشن را ببیند. اگر مدل را فهرست تخت نقش بسازید، ماه سوم مجبورید همه را بازنویسی کنید.

آنچه در صورت مسئله نیست ولی لازم می شود

- **تقویم تعطیلات رسمی** — قابل ویرایش، چون در ایران تعطیلی موردی اعلام می شود
- **مأموریت** — ثبت از بیرون محدوده با تأیید قبلی. بدون این، اولین کارمندی که به مأموریت می رود غایب ثبت می شود
- **قرارداد کارمند** — تاریخ شروع، نوع، حقوق پایه، حقوق بدون این محاسبه نمی شود

- **لاگ ممیزی** — برای هر چیزی که به پول می خورد غیر قابل مذاکره
- **حالت آفلاین** — صف محلی، ولی سرور زمان رسیدن خودش را مهر بزند و تأخیر را پرچم کند — وگرنه خودش یک راه دور زدن ژئوفنس است

هاست و دامنه

دامنه ها — سه تا

وضعیت	چیست	دامنه
موجود	بیکری	bafeh.com
جدید	منوی چندزبانه	دامنه رشن
جدید	مدیریت + منابع انسانی	دامنه داشبورد

زیر دامنه هم کافی است و یک هزینه سالانه کم می کند. ولی چون داشبورد هر دو کسب و کار را پوشش می دهد، زیر مجموعه بافه بودنش به کارمند رشن حس اشتباه می دهد. **تصمیم بر نندینگ است نه فنی** — هر دو کار می کند.

حکم درباره هاست اشتراکی

است با چند ده سفارش در روز؛ منو فقط خواندنی و B2B مقیاس واقعی کار را حساب کنید؛ بیکری کش شدنی است؛ حضور و غیاب با پنجاه کارمند یعنی صد درخواست در روز.

واقعی دارند cron **این بار روی هاست اشتراکی معمولی می نشیند**. سی پنل و دایرکت ادمین هر دو، و هر دو از چند دامنه پشتیبانی می کنند. با هاستی که دارید شروع کنید — ولی اول سه چیز را قطعی کنید

سه چیزی که باید قطعی شود

چه چیزی	چرا مرگبار است
php-soap	کار می کند. اگر نباشد وقتی SOAP پیامک ملی پیامک با Select می فهمید که همه چیز ساخته شده. در سی پنل از معمولاً خودتان فعالش می کنید PHP Version
ZipArchive	خروجی اکسل گزارش ها. معمولاً هست
تماس سرور به سرور	داشبورد از همین راه داده می گیرد. بعضی هاست ها می بندند و هیچ کس تا روز اتصال نمی فهمد

دقیقاً هر سه را می سنجد. روی **هر سه هاست** اجراش کنید، نتیجه را `tools/host-check.php` ابزار ببینید، و بعد پاکش کنید.

دو سناریو: یک هاست یا هاست های جدا

این مهم ترین نکته این بخش است: **فرقشان صفر خط کد است**

است و هیچ فرضی درباره محل نشستن سایت ها ندارد، جابه جا کردن HTTPS چون قرارداد کانکتور فقط هر سایت فقط **یک نشانی در تنظیمات** را عوض می کند

هاست های جدا	یک هاست	
یکسان	یکسان	کد
شاید ۲۰۰ میلی ثانیه	چند میلی ثانیه	سرعت تماس
هیچ	هیچ (داشبورد کش می کند)	تأثیر بر کاربر
سه تا	یکی	پیامک whitelist آی پی برای
قوی	ضعیف	جداسازی امنیتی
بیشتر	کمتر	هزینه

توصیه من — حالت میانی

سیستم منابع انسانی **کد ملی، حقوق و شماره حساب کارکنان** را نگه می دارد. اگر هر سه سایت روی یک اکانت سی پنل باشند، یک نفوذ به **سایت منو** — که عمومی ترین و پربازدیدترین است — به همان فایل سیستمی می رسد که دیتابیس حقوق در آن است.

داشبورد را روی یک اکانت سی پنل جدا بگذارید، حتی اگر همان سرور باشد. دو سایت عمومی می توانند کنار هم بمانند

متفاوت. جداسازی یعنی اگر یکی خراب شد بقیه سالم اند، و **prefix** و **سه دیتابیس جدا، نه یکی با** بکاپ و بازگردانی هر کدام مستقل است.

کی به سرور مجازی بروید

زودتر از این سه علامت لازم نیست

- هاست به خاطر مصرف اخطار داد
- منو در ساعت شلوغ کند شد
- تعداد کارکنان از حدود ۱۰۰ گذشت

پول دادن برای مشکلی است که هنوز ندارید VPS تا آن روز، خرید

امنیت

کلیدها

جدا دارد — نه یک کلید مشترک. اگر کلید رشن لو برود، نباید به داده مالی بافه HMAC هر سایت یک کلید برسد.

بمانند، نه در دیتابیس. دلیلش عملی است: بکاپ دیتابیس مدام جابه جا `wp-config.php` کلیدها در می شود — ایمیل، دانلود، دادن به توسعه دهنده. فایل پیکربندی نه

داده حساس کارکنان

کد ملی، حقوق، شماره حساب، آدرس منزل و موقعیت مکانی لحظه به لحظه. این حساس ترین داده ای است که در کل این سه سامانه وجود دارد — بیشتر از داده مالی کافه ها

سه قاعده:

- **داده موقعیت عمر محدود داشته باشد.** مختصات خام پس از مدتی (مثلاً شش ماه) پاک شوند و فقط «داخل/خارج» بماند. نگه داشتن رد حرکت کارمندان تا ابد، نه لازم است نه درست.
- **کارمند خودش ببیند چه چیزی از او ثبت می شود.** اگر موقعیتش را می گیرید، باید در صفحه خودش ببیند. این هم اخلاقی است و هم جلوی اختلاف را می گیرد.
- **دسترسی به حقوق فقط برای نقش هایی که واقعاً لازم دارند.** مدیر شعبه لازم نیست حقوق تیمش را ببیند تا مرخصی شان را تأیید کند.

جداسازی

داشبورد روی اکانت جدا، دیتابیس جدا، کاربر دیتابیس جدا. این در بخش هاست توضیح داده شد ولی اینجا هم تکرارش می کنم چون تصمیم امنیتی است نه عملیاتی

چهار چیزی که نباید اتفاق بیفتد

نباید	چرا
ذخیره رمز کاربران سایت ها در داشبورد	یک نشستی و هر سه سامانه رفته
از مرورگر <code>mint</code> باز کردن	هرکس برای هرکس توکن می سازد
توکن چندبار مصرف یا طولانی	لاگ پراکسی یا تاریخچه مرورگر = کلید ورود
اعتماد به گفته کلاینت درباره موقعیت	DevTools جعل با یک کلیک در

دو چیز که همین الان باید انجام شوند

و بستن XML-RPC مستقل از کل این طرح، دو اصلاح در بافه ارزشش را دارد: خاموش کردن `/wp/v2/users` برای مهمان. هر دو در پتی پتی از قبل نوشته شده اند و فقط قابل انتقال اند

نام کاربری `/wp/v2/users` را پنهان می کند تا اسکرها چیزی پیدا نکنند. ولی مسیر `wp-admin` بافه عمداً همه حساب ها را به هر بازدیدکننده ای می دهد — یعنی همان دری که قفل بسته، از پنجره باز است.

فازبندی کار

ترتیب بر اساس **ریسک** چیده شده، نه سهولت. چیزی که ممکن است کل طرح را باطل کند، اول می آید.

فاز ۰ — قطعی کردن هاست

خروجی: می دانیم هر سه هاست پیش نیازها را دارند.

یا لوپ بک قرمز باشد، **هیچ کار دیگری** `soap` روی هر سه. اگر `tools/host-check.php` اجرای **شروع نمی شود تا حل شود**. این فاز چند ساعت است ولی از هفته ها دوباره کاری جلوگیری می کند.

فاز ۱ — قرارداد کانکتور روی کاغذ

خروجی: سند فنی قرارداد — مسیرها، شکل پاسخ ها، روش امضا

چون **رشن هنوز ساخته نشده**، این قرارداد باید پیش از شروع رشن نوشته شود. این تنها فرصتی است که دارید تا دو سایت یک شکل اتصال داشته باشند نه دو تا

SSO + فاز ۲ — کانکتور بافه

کار می کند SSO **خروجی:** از یک اسکرپت ساده، شاخص های بافه خوانده می شوند و یک لینک

این فاز عمداً **قبل از ساختن داشبورد** است. فرض بنیادین کل طرح این است که دو سامانه واقعاً به هم وصل می شوند. اگر این فرض **غلط باشد، بهتر است در هفته دوم بفهمیم نه ماه سوم**.

فاز ۳ — اسکلت داشبورد

خروجی: ورود، نقش *دامنه، رکورد کارمند، و صفحه عملیات با دکمه ورود به پنل بافه

منتقل می شوند `qk-crm` و زمان بند `class-roles.php` اینجا

در پایان این فاز خواسته اصلی شما برآورده شده: یک جا وارد می شوید، هر دو پنل بدون رمز باز می شوند، و آمار هر دو را یکجا می بینید.

فاز ۴ — مکان + شیف + حضور و غیاب

خروجی: کارمند از گوشی ثبت ورود می کند، مدیر صف بازبینی دارد.

پریسک ترین فاز، پس زود. و حتماً با داده واقعی تست شود: یک هفته، یک شعبه، چند کارمند واقعی، بدون اینکه فیش حقوقی به آن وصل باشد. تنها راه فهمیدن اینکه شعاع و آستانه دقت درست اند، همین است.

فاز ۵ — موتور درخواست‌ها

خروجی: مرخصی، مساعده و وام با زنجیره تأیید و دفتر کل مالی

فاز ۶ — فیش حقوقی

خروجی: فیش ماهانه بر پایه حضور واقعی

فقط وقتی شروع می‌شود که داده حضور قابل اعتماد شده باشد. فیش حقوقی روی داده مشکوک، بدتر از نداشتن سیستم است — چون اعتماد کارکنان را یک بار و برای همیشه می‌سوزاند

فاز ۷ — رشن + کانکتورش

خروجی: منوی چندزبانه روی هوا، وصل به داشبورد

می‌تواند موازی با فازهای ۴ تا ۶ پیش برود، چون مستقل است — **به شرطی که قرارداد فاز ۱ رعایت شود.**

خلاصه

فاز	کار	وابسته به
۰	قطعی کردن هاست	—
۱	قرارداد کانکتور	—
۲	SSO + کانکتور بافه	۰، ۱
۳	اسکلت داشبورد	۲
۴	شیفت + حضور و غیاب	۳
۵	موتور درخواست‌ها	۴
۶	فیش حقوقی	۴، ۵
۷	رشن	۱

ریسک‌ها و تصمیم‌های باز

سه ریسک اصلی

اگر میزبان فعالش نکند، کل سیستم پیامک می‌میرد — نه فقط در بافه، **php-soap** **هاست بدون ۱۰** این یعنی SOAP. REST دارد نه بلکه اعلان‌های منابع انسانی هم. **راه جایگزین:** سرویس پیامکی که بازنویسی مازول پیامک بافه و ثبت دوباره همه پترن‌ها — کار قابل توجهی. به همین دلیل فاز ۰ اول است

جعل موقعیت مکانی. با وب قابل بستن نیست. لایه های دفاعی جلوی جعل تصادفی را می گیرند، ولی ۲۰ کسی که جدی باشد راه پیدا می کند. **اگر روزی این جدی شد، تنها جواب قطعی اپ نیتو است** که سیستم عامل را می خواند. اسکیم را طوری بسازید که اضافه کردنش بعداً مهاجرت mock location فلگ نخواهد.

قوانین حقوق و دستمزد. این جایی است که اشتباه پیامد حقوقی دارد، نه فقط فنی. من ساختار را ۳۰ طوری می سازم که نرخ ها داده باشند نه کد، ولی **خود نرخ ها را باید حسابدار شما بدهد و هر سال تأیید کند.**

تصمیم هایی که هنوز جواب ندارند

سؤال	چرا مهم است	لازم در فاز
چند کارمند، در چند مکان؟	نفر در یک شعبه با ۲۰۰ نفر در پنج شعبه دو طراحی ۱۰ متفاوت است	۳
مختصات دقیق مکان ها	بدون آن ژئوفنس معنا ندارد	۴
اینترنت ثابت دارد؟ IP آیا شعبه	قوی ترین سیگنال ضد جعل، مجانی	۴
زنجیره تأیید واقعی	مرخصی را کی تأیید می کند؟ وام فرق دارد؟	۵
قوانین حقوق از حسابدار	بدونش فیش ساخته نمی شود	۶
دامنه داشبورد و رشن	باید ثبت شوند	۰
زبان های رشن	فقط انگلیسی یا عربی هم؟	۷

چیزی که عمداً در این طرح نیست

سفارش آنلاین برای رشن. شما گفتید فعلاً فقط نمایش. این تصمیم درستی است — منوی نمایشی چندزبانه را می شود زود بالا آورد و دید مشتری چه نگاه می کند، بعد تصمیم گرفت که سفارش لازم هست یا (features.orders). نه. قرارداد کانکتور از همین حالا جایش را باز می گذارد

آن برای کسب و کار دیگری است و در این طرح فقط **منبع الگو** است، نه سامانه ای که **qk-crm** ادغام وصل می شود.

قدم بعدی

۱۰. `tools/host-check.php` را روی هاست اجرا کنید و نتیجه را بگویید ۲. من قرارداد کانکتور و طرح ۳. کانکتور بافه را می سازم — کوچک و بی خطر، و اتصال را زود اثبات می کند. فاز ۱) ۳. کانکتور بافه را می سازم — کوچک و بی خطر، و اتصال را زود اثبات می کند. فاز ۱ به هاست وابسته نیست و می شود موازی شروع کرد.